vulnerable to snooping. Any personal information about the user included in the token, such as their name, date of birth, job role, work location, and so on may be at risk if the token is accidentally leaked by the client or stolen though a phishing attack or XSS exfiltration. Some attributes may also need to be kept confidential from the user themselves, such as any attributes that reveal details of the API implementation. In chapter 7, you'll also consider third-party client applications that may not be trusted to know details about who the user is.

Encryption is a complex topic with many potential pitfalls, but it can be used successfully if you stick to well-studied algorithms and follow some basic rules. The goal of encryption is to ensure the confidentiality of a message by converting it into an obscured form, known as the *ciphertext*, using a secret key. The algorithm is known as a *cipher*. The recipient can then use the same secret key to recover the original plaintext message. When the sender and recipient both use the same key, this is known as *secret key cryptography*. There are also *public key* encryption algorithms in which the sender and recipient have different keys, but you won't cover those in much detail in this book.

> **DEFINITION** In ***secret key cryptography*** (also known as ***symmetric cryptography***) the sender and recipient use the same key to encrypt and decrypt messages. In ***public key cryptography*** the sender and recipient use different (but mathematically related) keys.